

AUTONOMOUS AI SOC PLATFORM OPEN AI **CAPSTONE PROJECT REPORT**

1. Problem Analysis

Business Context

Security Operations Centres (SOCs) are the frontline defense for organisations against cyber threats, responsible for continuously monitoring, detecting, and responding to security incidents across an enterprise's IT infrastructure. However, traditional SOCs face a critical operational bottleneck: the sheer volume of security alerts generated daily by SIEM (Security Information and Event Management) systems far exceeds the capacity of human analysts to triage them in real time. Industry reports consistently show that Tier-1 analysts are forced to manually sift through thousands of log entries and alerts per shift, leading to alert fatigue, delayed response times, and an increased risk of critical threats slipping through undetected.

Compounding this problem is a well-documented global shortage of skilled cybersecurity professionals, meaning most organisations particularly mid-sized enterprises without the budget for a 24/7 fully staffed SOC operate with under-resourced security teams. This creates a widening gap between the speed at which modern cyberattacks (ransomware, credential dumping, lateral movement) unfold and the speed at which human-only teams can investigate and contain them.

An AI-powered SOC platform directly addresses this gap by automating the repetitive, time intensive stages of the incident response lifecycle log analysis, threat intelligence correlation, and root-cause investigation while preserving human oversight for high-risk containment decisions. This allows human analysts to focus their expertise on judgment calls and strategic decision-making rather than manual data correlation.

Stakeholders

- **Tier-1 & Tier-2 SOC Analysts:** the primary day-to-day users of the platform, who rely on it to reduce alert triage time and receive structured, pre investigated incident summaries instead of raw, unstructured log data.
- **CISO / Security Leadership:** consumers of the executive-level reporting view, who need high level visibility into incident severity, response times (MTTD/MTTR), and organisational risk posture without needing to read technical logs.
- **Incident Response Teams:** who depend on the platform's containment recommendations (e.g., host isolation, IP blocking) and forensic attack tree reconstruction to accelerate remediation.
- **Compliance & Audit Teams:** who benefit from the automatically generated, structured post-mortem reports as documented evidence for regulatory and internal audit requirements.
- **IT/Network Administrators:** who are the ones ultimately executing or being affected by containment actions (e.g., a device being isolated from the network), and therefore have a direct stake in the accuracy of the Human in the Loop approval process.
- **End Users/Employees:** indirectly affected stakeholders whose devices, accounts, or data may be the subject of an investigation or containment action.

Problem Statement

Modern organisations generate a volume of security alerts and system logs that exceeds what human SOC teams can manually investigate in a timely manner, resulting in delayed threat detection, inconsistent incident documentation, and increased organisational exposure to cyberattacks such as ransomware, credential theft, and command-and-control (C2) beaconing. There is a need for an intelligent, autonomous system that can ingest raw security alerts, correlate them against threat intelligence and internal security playbooks, investigate root cause using established frameworks (e.g., MITRE ATT&CK), and recommend or execute containment actions, all while ensuring that any high-risk or irreversible

action (such as isolating a host or blocking network traffic) is explicitly reviewed and approved by a human analyst before execution.

Objectives

- Design and implement a multi-agent AI system where each agent specialises in a discrete stage of the SOC workflow, detection, threat intelligence enrichment, investigation, incident response, and reporting, mirroring the division of labour in a real enterprise SOC team.
- Reduce Mean Time to Detect (MTTD) and Mean Time to Respond (MTTR) by automating alert correlation and root-cause analysis that would otherwise require manual cross-referencing of logs, IP reputation databases, and internal playbooks.
- Enforce a mandatory Human-in-the-Loop (HITL) approval gate for all high-risk containment actions, ensuring the system augments rather than replaces analyst judgment for consequential decisions.
- Map identified attack behaviour to the MITRE ATT&CK framework to provide analysts with a standardised, industry-recognised classification of the techniques used in an incident.
- Generate structured, standardised incident reports (severity, affected assets, root cause, actions taken) that can be consumed by both technical analysts and non-technical leadership, and passed downstream into alerting systems (e.g., Slack/Discord webhooks).
- Maintain full context and session persistence across the multi-agent pipeline, so that no investigative detail is lost as a case is handed off between agents.

2. Multi-Agent Design

Agent Architecture

The system adopts an orchestrated, sequential handoff multi agent architecture built on top of the OpenAI Agents SDK paradigm. Rather than

using a single monolithic LLM prompt, the platform decomposes the complex incident lifecycle into modular, specialized units of intelligence. Each agent operates with specific system prompts, tailored toolsets, scoped execution contexts, and formal handoff definitions.

Context is preserved across the pipeline via shared state objects passed seamlessly between agents during handoffs. An event-driven state machine tracks execution milestones, dynamically pausing execution when sensitive firewall or host isolation tools are called to enforce mandatory Human-in-the-Loop (HITL) authorization gates.

Roles of Each Agent

- **1. Threat Detection Agent (*The Gatekeeper*):**
 - **Role:** Acts as the entry point for raw security events.
 - **Responsibilities:** Parses incoming SIEM logs, syslog streams, and raw alert payloads. Performs preliminary triage to classify threat severity (Low, Medium, High, Critical) and extracts primary Indicators of Compromise (IOCs) such as hostnames, user accounts, and remote IP addresses.
 - **Handoff Target:** Threat Intelligence Agent.

- **2. Threat Intelligence Agent (*The Investigator*):**
 - **Role:** Enriches extracted IOCs with global threat metrics.
 - **Responsibilities:** Executes background reputation queries against external and internal databases to assess malicious activity history, domain age, threat categories, and risk scores.
 - **Handoff Target:** Investigation Agent.

- **3. Investigation Agent (*The Detective*):**
 - **Role:** Performs forensic correlation and threat mapping.
 - **Responsibilities:** Cross-references alert context against organizational security policies and the MITRE ATT&CK

framework. Maps specific attack techniques (e.g., T1003 - OS Credential Dumping, T1490 - Inhibit System Recovery) and builds a forensic attack execution tree.

- **Handoff Target:** Incident Response Agent.

- **4. Incident Response Agent (*The Defender*):**

- **Role:** Formulates containment strategies and enforces safety gates.
- **Responsibilities:** Determines required remediation steps based on threat severity. Interacts directly with enforcement tools (such as network firewall blocks or host isolations), halting execution to prompt human analysts for sign-off whenever a high-risk action is triggered.
- **Handoff Target:** Self-Review Critic Agent.

- **5. Self-Review Critic Agent (*Quality Control*):**

- **Role:** Provides automated reflection and logic verification.
- **Responsibilities:** Reviews the accumulated investigative case file, verifies evidence links between IOCs and proposed root causes, eliminates false-positive hallucinations, and ensures compliance with internal SOC standards prior to report generation.
- **Handoff Target:** Security Report Agent.

- **6. Security Report Agent (*The Scribe*):**

- **Role:** Generates standardized post-mortem documentation.
- **Responsibilities:** Aggregates findings from all preceding agents to compile a structured incident summary containing root cause analysis, timeline of events, actions taken, and preventive recommendations. Outputs JSON schema data for UI rendering and database storage.

Agent Interaction and Handoff Flow

- **1. Initial Ingestion & Triage:**
 - Raw SIEM alerts and system logs enter the pipeline through the **Threat Detection Agent**.
 - The agent parses telemetry, extracts key Indicators of Compromise (IOCs), assigns an initial severity rating, and hands off the case context to the **Threat Intelligence Agent**.
- **2. Threat Intelligence Enrichment:**
 - The **Threat Intelligence Agent** receives the extracted IOCs (IPs, hashes, domain names).
 - It executes background reputation tools to gather risk scores, malicious vote counts, and threat categories, then hands off the enriched case file to the **Investigation Agent**.
- **3. Deep Investigation & Framework Mapping:**
 - The **Investigation Agent** analyzes the attack timeline alongside organizational policies and the MITRE ATT&CK framework.
 - It maps specific adversary tactics/techniques, constructs a forensic attack execution tree, and hands off the investigation to the **Incident Response Agent**.
- **4. Response Planning & Human-in-the-Loop Gate:**
 - The **Incident Response Agent** formulates containment recommendations based on the severity and nature of the threat.

- When a high-risk mitigation is triggered (e.g., firewall block or host isolation), execution automatically pauses at the **Human Approval Gate (HITL)**.
- A human analyst reviews proposed target assets, inspects reasoning, and submits authorization with sign-off notes.

- **5. Self-Review & Quality Assurance:**
 - Upon human sign-off, the case file transitions to the **Self-Review Critic Agent**.
 - The critic agent validates evidence links, filters potential hallucinations or false positives, and verifies compliance with SOC documentation standards before passing the final state to the **Security Report Agent**.

- **6. Final Report Generation & Persistence:**
 - The **Security Report Agent** compiles all findings into a structured post-mortem summary containing root causes, actions taken, and preventive steps.
 - The final output is rendered directly on the UI dashboard and persisted into the local relational database for long-term session history.

Tool Integration Overview

The agents interface with specialized software tools ("The Gadget Belt") to perform deterministic tasks, pull context, and execute network controls:

- **Log Reader** : Converts unformatted Syslog streams, JSON log dumps, and timestamped process logs into clean, human-readable plain text for agent ingestion.

- **Reputation Checker** : Queries threat intelligence APIs to look up reputation scores, threat tags, and past malicious activity associated with target IP addresses or file hashes.
- **Security Playbook Search** : A vector database search tool that retrieves internal organizational policy documents and standard operating procedures (SOPs) based on alert classification.
- **Vulnerability Lookup** : Cross-references software versions and process activity against known Common Vulnerabilities and Exposures (CVEs) to identify target asset flaws.
- **Host Isolator** : An enforcement execution module capable of issuing firewall block rules and disconnecting compromised host machines from the enterprise network upon receiving valid Human-in-the-Loop authorization.

3. Implementation

Specialised AI Agents

The platform deploys six specialized AI agents built on top of the OpenAI Agents SDK, each with tailored system instructions and scoped permissions:

- **Threat Detection Agent (*The Gatekeeper*)**: Ingests raw telemetry and syslog streams, extracts primary Indicators of Compromise (IOCs), and classifies initial threat severity.
- PDF

- **Threat Intelligence Agent (*The Investigator*)**: Focuses on external threat intelligence lookups to compute risk scores and threat categories.
PDF
- **Investigation Agent (*The Detective*)**: Correlates findings with internal policies, constructs attack execution trees, and maps tactics to the MITRE ATT&CK framework.
PDF
- **Incident Response Agent (*The Defender*)**: Formulates containment strategies and triggers enforcement tools.
PDF
- **Self-Review Critic Agent (*Quality Control*)**: Acts as a validation layer, verifying evidence chains and eliminating false-positive hallucinations before final output generation.
PDF
- **Security Report Agent (*The Scribe*)**: Synthesizes structured data into comprehensive executive summaries and post-mortem incident documentation.
PDF

Tools & Integrations

The architecture integrates five specialized execution tools ("The Gadget Belt"):

PDF

- **Log Reader**: Converts raw JSON log payloads and unstructured Syslog data into standardized, readable text.
PDF
- **Reputation Checker**: Interfaces with external threat intelligence sources (e.g., VirusTotal API) to evaluate IP, domain, and hash reputation.
PDF
- **Security Playbook Search**: A Retrieval-Augmented Generation (RAG) vector tool that queries internal organizational SOPs and

incident handling playbooks.

PDF

- **Vulnerability Lookup:** Cross-references active processes and host configurations against CVE databases to spot known system vulnerabilities.

PDF

- **Host Isolator:** An enforcement tool capable of issuing perimeter firewall blocks and isolating compromised workstations from the network upon receiving valid authorization.

PDF

Agent Handoff Mechanics

- **SDK Native Handoffs:** Agent transitions are managed natively using OpenAI Agents SDK handoffs.

PDF

- **State Passing:** Execution authority is passed along with a central IncidentContext data object, allowing each agent to inherit previous findings without relying on a centralized controller.

PDF

- **Dynamic Pipeline:** The orchestrator dynamically routes tasks based on agent outputs, moving seamlessly from detection to threat intel, investigation, response, reflection, and final reporting.

PDF

Memory & Context Management

- **Short-Term Session Memory:** Active context—including parsed IOCs, API response payloads, timeline events, and agent notes—is maintained in shared memory across the handoff lifecycle.

PDF

- **Long-Term Session Persistence:** Incident case files and execution logs are written to a local relational SQLite database. This ensures

historical cases remain accessible across UI sessions for compliance and reporting.

Structured Outputs

- **Schema Enforcement:** Strict Pydantic models enforce standardized JSON output schemas across all agents.
PDF
- **UI Data Binding:** Key fields such as Severity Level, Target Assets, Root Cause, MITRE ATT&CK Mapping, and Action Status render reliably on UI dashboard widgets.
PDF

Human-in-the-Loop Governance (HITL)

- **Safety Gates:** High-risk containment tools trigger an automated execution pause.
PDF
- **Authorization Modal:** The system issues a UI approval request displaying target assets, agent rationale, and potential impact.
PDF
- **Audit Trail:** Execution proceeds only after an analyst manually submits sign-off notes, recording an explicit human authorization entry in the incident log.
PDF

4. Advanced Features

- **Autonomous Planning & Multi-Step Reasoning:**
 - Rather than relying on static scripts, the agents use dynamic planning loops powered by the OpenAI Agents SDK.
 - Agents evaluate incoming incident telemetry on the fly to decide whether to query external threat intelligence feeds, perform

internal RAG lookups, map MITRE ATT&CK techniques, or escalate directly to response planning.

- **Knowledge Retrieval via RAG:**

- Implements Retrieval-Augmented Generation through the Security Playbook Search tool.
- Allows agents to perform semantic vector searches over internal organizational SOPs, security playbooks, and compliance standards to ground response recommendations in official company policy.

- **Self-Review & Reflection Loop:**

- Features a dedicated **Self-Review Critic Agent** that acts as an automated quality gate before final output generation.
- The agent evaluates accumulated investigative evidence, identifies logical gaps or potential false-positive hallucinations, and validates consistency between identified Indicators of Compromise (IOCs) and proposed remediation steps.

- **Session Persistence & Long-Term Memory:**

- Utilizes built-in SDK session management alongside a local relational SQLite database.
- Retains full multi-turn interaction state, agent execution traces, and historical incident cases, enabling analysts to retrieve, inspect, or resume past investigation workflows across web interface sessions.

- **Real-Time Observability & Logging:**

- Integrates an execution log terminal directly into the web UI dashboard.
 - Displays timestamped agent handoffs, tool execution parameters, API responses, and system status in real time to give human operators complete visibility into the autonomous decision pipeline.
-
- **Robust Error Handling & Fallbacks:**
 - Features defensive exception handling around external API integrations (e.g., threat intelligence lookups and CVE databases).
 - If an external service rate-limits or fails, tools gracefully fall back to local cached threat telemetry and flag the dependency status in the execution log without crashing the multi-agent pipeline.